HOW A RETRUST SCORE IS CALCULATED

ReTrust-OT V1, the formula and a worked example

Every figure in this document was read from the tool when it was built, not typed in. Re-run `python3 tools/build_scoring_sheet.py` after any scoring change and the example re-derives itself.

The shape: three layers

A single blended number is unsafe for procurement, because a genuine deal-breaker can be averaged away. So a verdict is built in three stages, and only the middle one is arithmetic.

	Layer	What it does
1	Hard gates	Known exploitation, ransomware linkage, a critical flaw with no fix, or supplier screening. Any one forces AVOID and no score is computed. Gates sit outside the formula so they cannot be out-voted.
2	Weighted score	The 0–100 product below, for anything that clears the gates.
3	Bands	≥ 70 PREFER · ≥ 40 CONDITIONAL · otherwise AVOID. An unmitigable flaw, such as a hardcoded credential with no fix, caps the result below PREFER.

Step 1 — one risk number per vulnerability

$$z = T' \times A \times H \times U$$
$$T' = 0.40 + 0.60\,T$$

The operator never types a 0–1 value. All four are derived from public evidence, and three of them can be narrowed by facts only the asset owner has. Every refinement is optional, and each can only reduce the assessed risk — saying nothing is already the conservative reading.

Term	Meaning	Read from	You may refine it with
T	Threat level	CISA KEV, ransomware flag, NIST LEV, FIRST EPSS	— evidence only, never asked
A	Attack reachability	the CVSS attack vector, present on 100% of 69,560 affected rows	verified interface block; declared network exposure; ruling out the privileges, interaction or attack conditions the vector demands
H	OT operational impact	the finding's own CVSS severity	declared process consequence
U	Unresolved applicability	CSAF remediation status	fix verified applied, or a verified mitigation

Worked on a real product — ABB AC 800M, worst three of 10 findings:

Vulnerability	T	T'	A	H	U	z
CVE-2021-22284	0.239	0.54	0.60	0.84	1.00	**0.274**
CVE-2020-8488	0.274	0.56	0.30	0.78	1.00	**0.132**
CVE-2020-8484	0.205	0.52	0.30	0.78	1.00	**0.122**

Step 2 — concentrate on the worst few

$$R = \min(1,\ z_1 + 0.20\ z_2 + 0.10\ z_3)$$
$$E = 100\ (1 - R)$$

Averaging is what a purchase decision least wants: a product with one catastrophic flaw and forty minor ones should not come out like forty-one middling ones. So the worst path enters at full weight, and the next two add on top of it rather than diluting it — a real device has more than one route in. The leading coefficient is 1.00 because an earlier 0.70 reserved 30% of the score for flaws the product did not have, capping a single catastrophic finding at E = 30 when it should reach 0.

Two costs come with this, and both are consequences of the formula rather than oversights. R clips at 1, so a product with three severe paths reaches exactly E = 0 and stops being rankable against a worse one — 5.7% of a 582-product sample lands there. And only three paths are counted, so three severe flaws and three hundred score alike.

$$R = 0.3127 \text{ over } 10 \text{ findings} \rightarrow E = 68.7$$

Step 3 — combine the four pillars

$$S = E^{0.60} \times P^{0.20} \times V^{0.15} \times C^{0.05}$$

A product, not a mean, so dangerous exposure cannot be bought back with a good vendor record and a certificate — the rule the gates enforce, applied to the weighted part. Pillars enter as 1–100, never 0, so one unmeasured term cannot annihilate the result; and a pillar with no evidence at all is excluded and the remaining exponents renormalised, never scored as a neutral 50.

Pillar	Meaning	Exponent	This product
E	Exposure safety	0.60	68.7
P	Patch and maintenance capability	0.20	52.0
V	Vendor security practices	0.15	100.0
C	Certification and assurance	0.05	100.0

$$68.7^{0.60} \times 52.0^{0.20} \times 100.0^{0.15} \times 100.0^{0.05} = 70.1 / 100 \rightarrow \text{PREFER}$$

The formula is implemented, not approximated

Fed the reference example’s own values, the tool’s functions return the reference results to four decimal places.

Reference step	Reference result	Tool’s function	Returns
R from one path, z = 0.48	0.48	exposure.concentrate()	**0.48**
E = 100(1 – R), one path	52	—	**52**
R from z = 0.48, 0.20, 0.10	0.53	exposure.concentrate()	**0.53**
E = 100(1 – R), three paths	47	—	**47**
S from E=34, P=70, V=80, C=60	45.95	score._composite()	**45.9492**

Five deliberate departures, each for a measured reason

#	Departure	Why

1	T is mapped onto [0.40, 1] rather than used raw	The OT corpus median EPSS is 0.007. Used directly, a critical, network-reachable, unfixed CVE gives z ≈ 0.007 and so E ≈ 99.5 — “harmless”, because nobody has attacked it yet. Threat now amplifies rather than decides.
2	H carries the finding’s CVSS severity, scaled by the declared consequence	The reference z has no severity term, so a CVSS 9.8 and a 4.0 with equal EPSS scored identically. This follows the reference’s own caveat that impact must consider what the vulnerability actually permits.
3	T reads LEV as well as KEV and EPSS	The reference specifies T = max(KEV, LEV, EPSS). LEV’s corpus median is 0.167 against EPSS’s 0.007, so for most OT findings it is the only non-trivial exploitation evidence there is. An observation still outranks any model: a KEV listing beats any estimate.
4	No operator declaration may promote the verdict	Measured with the clamp off: declarations produced 1,657 band promotions across 489 products, 552 of them AVOID straight to PREFER, and reordered 118 of 119 products in a comparison. Nobody can verify “isolated”. The undeclared score now sets the best band; declarations still move the number inside it.
5	C may lift the score but never lower it	As written, $C^{0.05}$ costs an uncertified product 20.6% of its score (57.8 against 72.7, measured). Most OT hardware is never submitted for certification, so absence is excluded rather than penalised.

What the number is, and is not

Higher is better	A score is how favourable the public evidence is, not a probability that the equipment is secure. 70/100 means low assessed risk, not “70% safe”.
Gates override it	A gated product is AVOID whatever the arithmetic says. Declaring an isolated network raises the number, and lifts neither the gate nor the band.
Counts are never scored	Raw CVE volume carries no weight, because that would rank a diligent discloser below a silent one.
Absence is not safety	An unresolved product is NOT ASSESSED, never a flattering 100. An unparseable version range stays in scope.
Evidence completeness is separate	It says how far to trust the score, not how risky the product is, so it is reported beside the verdict and never inside it.
The weights are arguable	They live in an editable config file, and `retrust sensitivity` re-runs the verdict under hundreds of random weightings; a verdict holding under fewer than 90% is flagged as a judgement call.

In one sentence: how bad are the worst few flaws on this device (60%), can you fix them (20%), does the vendor disclose well (15%), and is it independently certified (5%) — multiplied, so a dangerous product cannot be rescued by good paperwork.

ReTrust is decision support, not a certification. Figures come from public CISA, FIRST and vendor sources; the scoring version and data snapshot are recorded on every assessment so a result can be re-run and disputed.